

Island Tours Backend, Who Can Access What

Version: 1.6 · July 27, 2026 (Availability restructured as two surfaces on one model: per-tour setup under Tours, cross-tour daily agenda as the Availability section)

Answers: access levels per role for the tenancy / users / membership-levels test round.

Sources: island-tours-platform-master.md v1.17 (canonical, wins on any conflict), island-tours-login-design-spec.md v0.2, island-tours-operator-signup-flow.md v0.1.

Three ground rules

- 1. **Three separate logins, never merged:** end users on island.tours/bookings (email + booking reference pair, no passwords; self-service pages on the public site, never this backoffice), operator teams on operators.island.tours (password + mandatory TOTP 2FA), Island Tours staff on admin.island.tours (Google Workspace SSO + server-side allowlist).
- 2. **The membership levels are the two role enums already in master E.11:** operator seats = owner / manager / staff, Staff = admin / support / content . Commercial tiers (premium etc.) never change access, only ranking and commission.
- 3. **Tenancy:** every operator-scoped row (tours, departures, bookings, media, settlements, operator_users) carries operator_id , enforced in RLS. Operator seats reach their own operator's data only; staff roles see all operators. Enforce server-side: hiding a nav item is not authorization.

Access matrix

Full = read + write, all operators · Own = read + write, own operator only · View = read only · - = no access (nav hidden and API denied)

Section	admin	support	content	operator
Overview	Full	View	-	Own
Bookings	Full	Full	-	Own
Cancellations	Full	Triage	-	Own
Reviews	Full	Full	View	Own + reply
Customers	Full	Full	-	-
Operators	Full	View	-	-
Payments	Full	View	-	-
Settlements	Full	-	-	View own
Tours	Full	View	Full	Own, no publish
Availability	Full	View	-	Own
Media	Full	-	Full	Own tours
Translations	Full	-	Full	-
Users	Full	-	-	Own seats
Settings	Full	Prefs	Prefs	Own

Seat roles within one operator account

The operator column above is the account's maximum. Per seat:

- **owner** (the person who signed up and holds the agreement): the full operator column, including Settlements, payout/bank details, seat management, and tier selection. All of those demand step-up 2FA.
- **manager** (day-to-day lead): the same minus money and control: no Settlements, no payout/bank, no seats, no tier.
- **staff** (guides/desk): Bookings manifests only: lead name, party size, date/time, pickup, special requirements, phone. No amounts, no traveler email, no other sections.

Notes per section

- **Bookings:** the operator sees full bookings for their own tours, including guest contact details (name, email, phone) and per-booking payment state. Internal fields on a booking (click ids and UTM attribution, billing address data from Stripe, commission fields) are never rendered in the operator portal.
- **Cancellations:** manual in v1 (master 6.4): admin executes cancellations, refunds, and forfeit confirmations (fresh SSO). Support triages requests. Operators view their own, report balance non-payment and operator-forced cancellations, and never execute refunds or forfeits.
- **Reviews:** operators see reviews on own tours and may write one response per review, no editing afterwards; they can never edit, hide, or delete a review. Moderation = admin/support.
- **Customers:** the cross-booking traveler database, staff only. Operators get guest data inside their own Bookings only: no customer lists, no export, no marketing use.
- **Operators (add this to the staff nav):** the registry of operator companies, staff-side only and missing from the current nav: the signup approval queue (INT-1: one-click approve behind SSO, audit-logged, never an approve link inside an email), operator records (E.6), suspension, and Destination Spotlight approval (7.2). Without it there is no place to approve a signup.
- **Payments:** staff only; card data is never stored or shown (PCI stays with Stripe). The operator's money view = payment state per booking (Bookings) plus own statements in Settlements (manual in v1, rails are the open C23 item).
- **Tours:** operators create, edit, and submit own tours. Two kinds of edits: **operational fields** (pricing, booking cutoff) go live immediately, which is safe because every booking snapshots its amounts and commission at creation (E.8); **content fields** (title, copy, photos) go through our review, and **publishing is always ours** (content or admin). One exception on the operational side: `cancellation_hours` is computed into every booking's deadline at read time (E.8), so changing it on a live tour would retroactively move existing bookings' deadlines; on live tours that change is admin-only. Server-side publish preconditions: `approval_status = approved`, owner seat `totp_enrolled_at` set, `cancellation_hours` set from [24, 48, 72, 168]. Tier selection is per tour, with step-up and a 30-day lock.
- **Availability (two surfaces, one model):** split setup from daily use.
 - **Setup, per tour, as a tab under Tours:** the E.9 weekly schedule editor (times, seasons, capacity defaults) plus that tour's per-date exceptions. Rarely touched. This is where GetYourGuide and Viator put it too (inside the product).
 - **Daily ops, the Availability section in the nav:** one agenda across all of the operator's tours: today and the coming days per departure with booked/capacity, one-tap close per date or departure, bulk blackout across tours (a weather day closes everything in one action, not one action per tour), one-tap Close today, and the `availability_confirmed_at` freshness confirm. Mobile-first: this is the daily habit from the field. For a one-

tour operator the agenda simply shows that tour. This is the FareHarbor pattern: operators live in a cross-item calendar.

- Rules from E.9 apply on both surfaces: manual stop-sell always wins (an API sync never silently reopens a manual closure); capacity never drops below booked count (forcing it below is admin-only, fresh SSO). Why this must be the easiest part of the portal: a tour with no open departure in the next 30 days automatically drops out of every ranked listing and is not billed for its tier while unbookable (7.2), and `departures.sold_out_at` feeds the sell-out trigger. Canonical: E.9 plus island-tours-availability-dev-spec.md.
- **Media:** content manages the full library; operators upload/replace photos on own tours only, live only after review.
- **Translations:** content/admin only. Operator portal is EN-only in v1.
- **Users:** admin manages the staff allowlist and executes operator seat recovery. Operator seat management (invite, role, suspend, remove) sits with the owner; owner seats are only removed by another owner.
- **Settings:** admin = platform config. Operator = company profile, contact, notification prefs, and payout/bank details (owner only, step-up, email-notified). Every operator seat manages its own password, 2FA, trusted devices, and sessions.
- **Step-up everywhere it counts:** fresh 2FA for payout, bank, seat, and tier mutations; fresh SSO for admin refunds, forfeits, capacity below booked count, and allowlist changes. All of it audit-logged.

End users (travelers)

No access to this backoffice, no passwords, no roles. Their self-service lives on the public site: book and pay; island.tours/bookings pair login (email + booking reference) opens that single booking and its cancellation request; invoices and cross-booking history additionally require the one-time email code; saved tours; one review per confirmed booking via the post-tour email link. These pages hit the same API, but always scoped to that one booking via its signed token, never via a backend role.

Future designers

No backend account in v1: they work from the design handoff and staging with test data. If live data is ever needed, add a read-only `viewer` value to `admin_allowlist.role`; do not widen `content`.